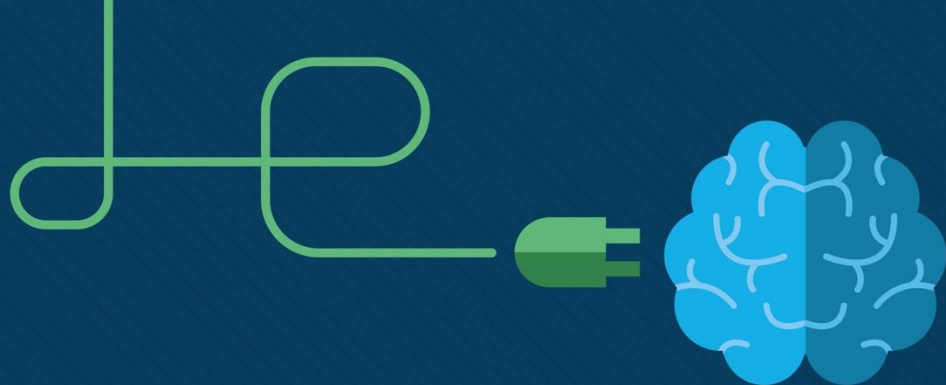




Módulo 25: Datos de seguridad de red



Objetivos del módulo

Título del módulo: Datos de seguridad en la red

Objetivos del módulo: Explicar los tipos de datos de seguridad en la red usados en el monitoreo de seguridad.

Título del tema	Objetivo del tema
Tipos de datos de seguridad	Describir los tipos de datos utilizados en el monitoreo de la seguridad.
Registros de terminales	Describir los elementos del archivo de registro de un terminal.
Registros de redes	Describir los elementos del archivo de registro de un dispositivo de red.

25.1 Tipos de datos de seguridad

Datos de la alerta

- Los datos de alertas son mensajes generados por sistemas de prevención de intrusiones (IPS) o sistemas de detección de intrusiones (IDS) para responder al tráfico que viola una regla o coincide con la firma de un ataque conocido.
- Las alertas son generadas por Snort y son legibles y buscarles por las aplicaciones Sguil y Squert.
- Un sitio de prueba que se utiliza para determinar si el Snort que está operando es del sitio tesmyids. Consiste en una sola página web que muestra el siguiente texto:

uid=0 (root) gid=0 (root) grupos=0 (root)

Datos de alerta

- Si Snort funciona correctamente y un host visita este sitio, una firma coincidirá y se activará una alerta.
- La regla de Snort que se activa es la siguiente:

```
alert ip any any -> any any (msg:"GPL ATTACK\_RESPONSE id check  
returned root"; content:"uid=0|28|root|29|"; fast\_pattern:only;  
classtype:bad-unknown; sid:2100498; rev:8;)
```

- Esta regla genera una alerta si **cualquier dirección IP** en la red recibe datos desde una fuente externa que contengan texto que coincida con el patrón de **uid=0(root)**.
- La alerta contiene el mensaje **GPL ATTACK_RESPONSE id check returned root**. El ID de la regla Snort que se activó es **2100498**.

Datos de seguridad de la red

Datos de alerta

- La línea resaltada de la figura muestra una alerta Squil.
- La regla Snort y los datos del paquete para el contenido recibido de la página web testmyvids se muestran en el área inferior derecha de la interfaz de Squil.

The screenshot shows the Squil 0.9.0 interface. The top bar indicates 'SQUIL-0.9.0 - Connected To localhost'. Below the menu bar, the 'RealTime Events' tab is active, displaying a table of events. The table has columns: ST, CNT, Sensor, Alert ID, Date/Time, Src IP, SPort, Dst IP, DPort, Pr, and Event Message. The event with Alert ID 5.362 is highlighted in yellow. Below the table, the 'System Msgs' tab is active, showing a detailed view of the selected event. The 'Show Packet Data' and 'Show Rule' checkboxes are checked. The rule text is displayed, followed by the packet details for the selected event, including the IP header, TCP header, and the data payload.

ST	CNT	Sensor	Alert ID	Date/Time	Src IP	SPort	Dst IP	DPort	Pr	Event Message
RT	1	seconion...	5.1482	2020-05-10 21:20:55	209.165.201.17	52332	209.165.200.235	80	6	ET WEB_SPECIFIC_APPS phpSkelSite theme parameter remote file inclusi
RT	1	seconion...	7.1795	2020-05-10 21:20:55	209.165.201.17	52332	209.165.200.235	80	6	ET WEB_SPECIFIC_APPS phpSkelSite theme parameter remote file inclusi
RT	1	seconion...	7.1688	2020-05-10 21:20:52	209.165.201.17	52298	209.165.200.235	80	6	ET WEB_SPECIFIC_APPS phpSkelSite mp3_id.php GLOBALS Parameter F
RT	1	seconion...	5.1375	2020-05-10 21:20:52	209.165.201.17	52298	209.165.200.235	80	6	ET WEB_SPECIFIC_APPS phpSkelSite mp3_id.php GLOBALS Parameter F
RT	1	seconion...	5.1580	2020-05-10 21:21:17	209.165.201.17	52414	209.165.200.235	80	6	ET WORM TheMoon.linksys.router 1
RT	1	seconion...	7.1893	2020-05-10 21:21:17	209.165.201.17	52414	209.165.200.235	80	6	ET WORM TheMoon.linksys.router 1
RT	4	seconion...	5.362	2020-05-10 20:58:01	209.165.200.235	6200	209.165.201.17	37071	6	GPL ATTACK_RESPONSE id check returned root
RT	4	seconion...	7.675	2020-05-10 20:58:01	209.165.200.235	6200	209.165.201.17	37071	6	GPL ATTACK_RESPONSE id check returned root
RT	12	seconion...	7.690	2020-05-10 21:20:25	209.165.201.17	52158	209.165.200.235	80	6	GPL EXPLOIT .cnf access
RT	12	seconion...	5.377	2020-05-10 21:20:25	209.165.201.17	52158	209.165.200.235	80	6	GPL EXPLOIT .cnf access
RT	8	seconion...	7.683	2020-05-10 21:20:25	209.165.201.17	52156	209.165.200.235	80	6	GPL EXPLOIT .ht access
RT	8	seconion...	5.370	2020-05-10 21:20:25	209.165.201.17	52156	209.165.200.235	80	6	GPL EXPLOIT .ht access
RT	1	seconion...	5.1055	2020-05-10 21:20:49	209.165.201.17	52238	209.165.200.235	80	6	GPL EXPLOIT /loadmpw/axp2.ht access
RT	1	seconion...	7.1368	2020-05-10 21:20:49	209.165.201.17	52238	209.165.200.235	80	6	GPL EXPLOIT /loadmpw/axp2.ht access

IP Resolution Agent Status Snort Statistics System Msgs User Msgs

☐ Reverse DNS ☒ Enable External DNS

Src IP:

Dst IP:

Whols Query: ☐ None ☐ Src IP ☐ Dst IP

☒ Show Packet Data ☒ Show Rule

Alert IP any any -> any any (msg="GPL ATTACK_RESPONSE id check returned root"; content:"uid=0[28]root[29]"; fast_pattern:only; classtype:bad-unknown; sid 2100408; rev:8; metadata:created_at 2010_09_23, updated_at 2010_09_23;) /msm/server_data/security/snort/rules/seconion-ers192-1/downloaded.rules: Line 700

IP	Source IP	Dest IP	Ver	HL	TOS	len	ID	Flags	Offset	TTL	ChkSum
	209.165.200.235	209.165.201.17	4	5	0	76	13818	2	0	64	53097

TCP	Source Port	Dest Port	R	R	R	R	C	S	S	Y	I
	Port	Port	1	0	G	K	H	T	N	N	Seq #
	6200	37071	-	-	-	X	X	-	-	-	2269574096
	75	69	64	3D	39	28	72	6F	6F	74	29
	39	28	72	6F	6F	74	29	8A	-	-	0

DATA

uid=0(root) gid=0(root).

Search Packet Payload ☐ Hex ☐ Text ☐ NoCase

Consola de Squil mostrando alerta de prueba de Snort IDS

Datos de sesiones y datos de transacciones

- Los datos de sesión son un registro de una conversación entre dos terminales de red que suelen ser un cliente y un servidor. El servidor puede encontrarse dentro de la red empresarial o en un lugar al que se tiene acceso por Internet.
- Los datos de sesión son datos sobre la sesión, no los datos que recupera y utiliza el cliente.
- Los datos de la sesión incluyen información de identificación, como las **cinco tuplas** de direcciones IP de origen y destino, el número de puerto de origen y de destino, y el código IP del protocolo en uso.
- Los datos sobre la sesión incluyen un identificador de la sesión, la cantidad de datos transferidos por el origen y el destino, e información relativa a la duración de la sesión.

Datos de sesión y transacción

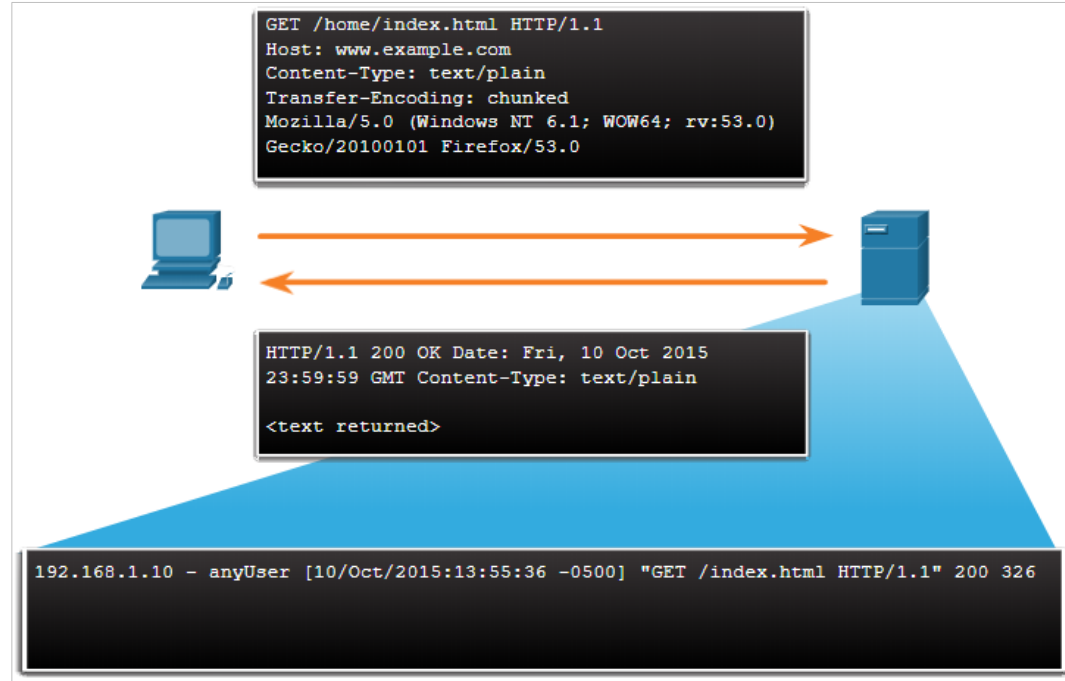
La figura muestra un resultado parcial para estas tres sesiones de HTTP desde un registro de conexión de Zeek.

1	2	3	4	5	6	7	8	9	10	11	12	13
ts	uid	id.orig_h	id.orig_p	id.resp_h	id.resp_p	proto	service	duration	orig_bytes	resp_bytes	orig_pkts	resp_pkts
1320279567	CEv1Z54N5gT3PwJLog	192.168.2.76	52034	174.129.249.33	80	tcp	http	0.082899	389	1495	5	4
1320279567	CI6Ueb3SkSJHwASNIN4	192.168.2.76	52035	184.72.234.3	80	tcp	http	2.56194	905	731	9	8
1320279567	CaTMSv1Sb8HtFunqj	192.168.2.76	52033	184.72.234.3	80	tcp	http	3.345539	1856	1445	15	13

1. **ts**: session start timestamp
2. **uid**: unique session ID
3. **id.orig_h**: IP address of host that originated the session (source address)
4. **id.orig_p**: protocol port for the originating host (source port)
5. **id.resp_h**: IP address of host responding to the originating host (destination address)
6. **id.resp_p**: protocol of responding host (destination port)
7. **proto**: transport layer protocol for session
8. **service**: application layer protocol
9. **duration**: duration of the session
10. **orig_bytes**: bytes from originating host
11. **resp_bytes**: bytes from responding host
12. **orig_packets**: packets from the originating host
13. **resp_packets**: packets from responding host

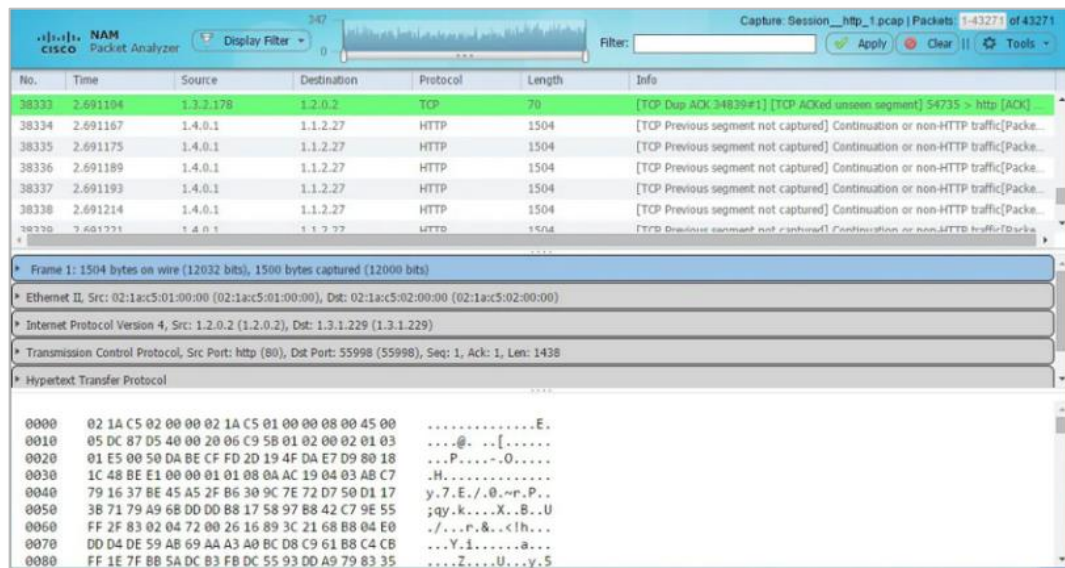
Datos de sesión y transacción

- Los datos de transacciones son los mensajes que se intercambian durante sesiones de red.
- Es posible ver estas transacciones en las transcripciones de captura de paquetes.
- Las transacciones que representan las solicitudes y respuestas deberían de ser registradas en un acceso de registro en el servidor o mediante un NIDS como Zeek.
- Una sesión podría incluir la descarga del contenido por medio de un servidor web, como se muestra en la figura.



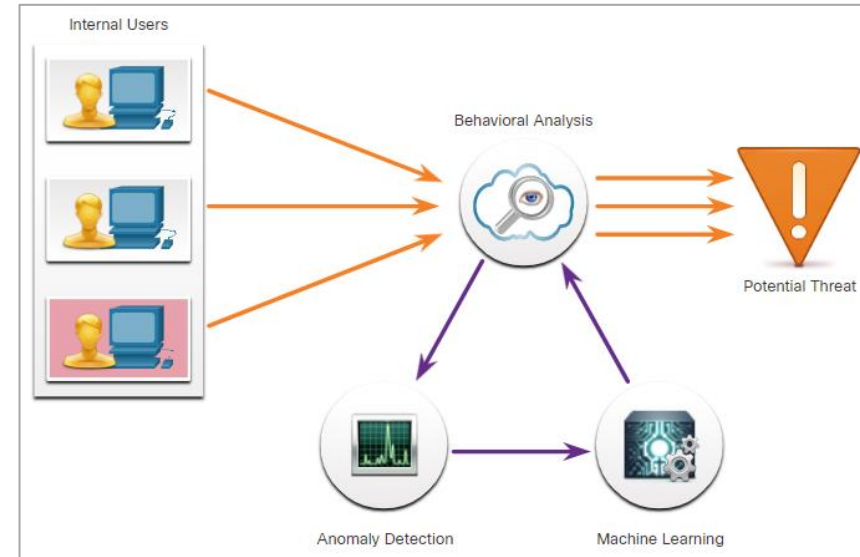
Capturas de paquetes completos

- Las capturas de paquetes completos son la más detallada captura de datos en la red que son recolectados en general.
- Contienen el material actual de las conversaciones, así como texto de mensajes de correo electrónico, El HTML en las paginas web, y los archivos que entran o salen de la red.
- El contenido que se extrae de las capturas de paquetes completos puede recuperarse y analizarse en busca de malware o comportamiento del usuario que viole las políticas de la empresa y de seguridad.
- En la figura, se ejemplifica la interfaz de Network Analysis Monitor, un componente del sistema de la infraestructura Cisco Prime que, como Wireshark, puede mostrar capturas de paquetes completos.



Datos estadísticos

- Los datos estadísticos son sobre el tráfico en la red el cual se crea a través del análisis de otras formas de datos de red.
- Las estadísticas pueden utilizarse para caracterizar volúmenes normales de variación en los patrones de tráfico de red con el fin de identificar las condiciones de red que están significativamente fuera de esos rangos.
- Un ejemplo de una herramienta de NSM que utiliza el análisis estadístico es Cisco Cognitive Threat Analytics.
- Es capaz de encontrar actividad maliciosa que ha evitado los controles de seguridad o que ingresó por canales no monitoreados (incluidos medios extraíbles) y está funcionando dentro del entorno de una organización.
- La figura muestra una arquitectura para Cisco cognitive threat Analytics.



25.2 Registros de terminales

Archivos de registro del host

- El sistema de detección de intrusiones basado en hosts (Host-based Intrusion detection system, HIDS), se ejecuta en hosts individuales.
- Muchas protecciones basadas en host envían registros a servidores de administración de registros centralizados que se pueden buscar desde una ubicación central mediante herramientas de NSM.
- Los archivos de registro de los hosts Microsoft Windows pueden verse a nivel local en el Visor de eventos. El Visor de eventos tiene cuatro tipos de archivos de registro:
 - **Registros de aplicaciones** – Contienen eventos registrados por varias aplicaciones.
 - **Registros de sistema** – Incluyen eventos relativos al funcionamiento de controladores, procesos y hardware.
 - **Registros de configuraciones** – Registran información sobre la instalación de software, incluidas las actualizaciones de Windows.
 - **Registros de seguridad** – Registran eventos relativos a la seguridad, como los intentos de inicio de sesión y las operaciones relacionadas con el acceso a archivos u objetos y su administración.
 - **Registros de línea de comandos** – Los atacantes que han obtenido acceso a un sistema y algunos tipos de malware ejecutan comandos desde la interfaz de línea de comandos (CLI) en lugar de una GUI. La ejecución de la línea de comandos de registro proporcionará visibilidad de este tipo de incidente.

Registros de host

- Los diversos registros pueden tener diferentes tipos de eventos. Los registros de seguridad incluyen solamente mensajes de éxito o fracaso de las auditorías.
- En computadoras con Windows, el Servicio de subsistema de autoridad de seguridad local (LSASS, Local Security Authority Subsystem Service) lleva a cabo el registro y también es responsable de implementar las políticas de seguridad en un host de Windows.
- LSASS funciona como lsass.exe. Con frecuencia, se usa malware para hacerse pasar por este servicio. Debe ejecutarse desde el directorio System32 de Windows.
- Si un archivo con este nombre, o uno camuflado como lsass.exe, se está ejecutando o se está corriendo desde otro directorio, podría ser malware.
- Los eventos de Windows se identifican mediante números de identificación y descripciones breves. Una enciclopedia de ID de eventos de seguridad, algunos con detalles adicionales, está disponible en Ultimate Windows Security en la Web.

Registros de host

La tabla explica el significado de los cinco tipos de eventos de registro de host de Windows.

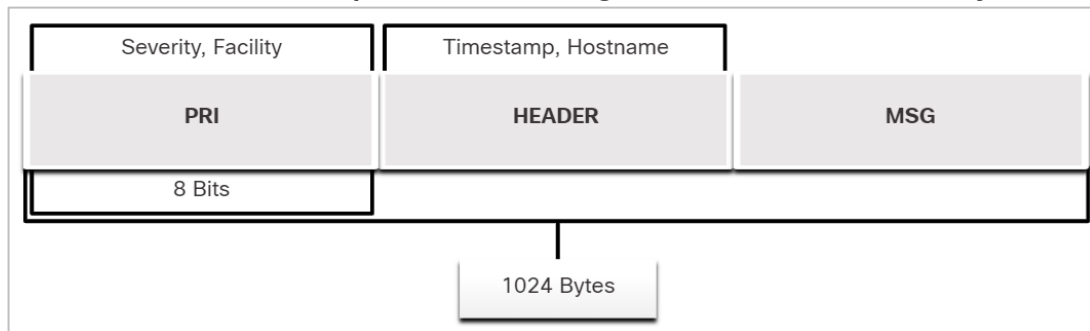
Tipo de evento	Descripción
Error	Es un evento que indica la presencia de un problema significativo como pérdida de datos o funcionalidad. Por ejemplo, si un servicio no se carga durante el arranque, se registra un evento de error.
Advertencia	Es un evento que no es necesariamente significativo, pero que pueden indicar un posible problema en el futuro. Por ejemplo, se registra un evento de advertencia cuando hay poco espacio en el disco. Si una aplicación se recupera de un evento sin perder ninguna funcionalidad o datos, el mismo puede ser calificado como un evento de advertencia.
Información	Describe el correcto funcionamiento de una aplicación, controlador o servicio. Por ejemplo, cuando se carga correctamente un controlador de red, puede ser adecuado registrar un evento de información. Tengan presente que generalmente no es adecuado que una aplicación de escritorio registre un evento cada vez que se inicia.
Auditoría exitosa	Es un evento que registra un intento de acceso de seguridad auditado que tuvo éxito. Por ejemplo, un usuario logra iniciar sesión en el sistema este es un evento de auditoría exitoso
Auditoría fallida	Es un evento que registra un intento de acceso de seguridad auditado que no tuvo éxito. Por ejemplo, si un usuario intenta tener acceso a una unidad de red y no lo logra, el intento se registra como un evento de auditoría fallida.

Syslog

- Syslog incluye especificaciones para formatos de mensajes, una estructura de aplicación de cliente y servidor, y un protocolo de red.
- Muchos tipos diferentes de dispositivos de red pueden configurarse para utilizar el estándar de syslog a fin de registrar eventos en los servidores de syslog centralizados.
- Syslog es un protocolo entre cliente y servidor. Se definió dentro del grupo de trabajo de Syslog de la IETF (RFC 5424) y es compatible con una amplia variedad de dispositivos y receptores en múltiples plataformas.
- El emisor de Syslog envía un mensaje de texto breve (menos de 1 KB) al receptor de Syslog. El receptor de Syslog es comúnmente llamado “syslogd”, “daemon de syslog” o “servidor de syslog”.
- Es posible enviar mensajes de syslog mediante UDP (puerto 514) o TCP (normalmente, el puerto 5000).

Syslog

- El formato completo de un mensaje Syslog tiene tres partes distintas, como PRI (prioridad), HEADER(encabezado), MSG (texto del mensaje).
- El PRI consiste de dos elementos, las instalaciones y la gravedad del mensaje, los cuales son valores enteros.
- La instalación consiste en fuentes(sources) que generan mensajes, como el sistema, el proceso o la aplicación. Los servidores de registro pueden usar el valor del componente para dirigir el mensaje al archivo de registro correspondiente.
- La gravedad es un valor de 0 a 7 que define la gravedad del mensaje.



Syslog

Las descripciones del paquete Syslog son las siguientes:

Instalación

- Los códigos de instalación entre el 15 y el 23 (local0-local7) no tienen asignado un nombre o nombre clave.
- Se pueden asignar a otros significados dependiendo del contexto de uso. Además, se ha descubierto que diversos sistemas operativos utilizan los componentes 9 y 15 para los mensajes de reloj.

Gravedad

Valor	Gravedad
0	Emergencia: El sistema no puede utilizarse
1	Alerta: Se deben tomar acciones inmediatamente
2	Críticas: Condiciones críticas que deben corregirse inmediatamente e indican un fallo en un sistema
3	Error: Un fallo que no es urgente, debe resolverse dentro de un plazo determinado
4	Advertencia: Actualmente no existe un error; sin embargo, se producirá un error en el futuro si no se soluciona la condición
5	Aviso: Un evento que no es un error, pero que se considera inusual. No requiere una acción inmediata.
6	Información: mensajes emitidos sobre el funcionamiento normal
7	Depuración: mensajes de interés para los desarrolladores

Prioridad

- El valor de prioridad (PRI) se calcula multiplicando el valor de instalación por 8, y luego añadiéndole el valor de gravedad, como se muestra a continuación.

$$\text{Prioridad} = (\text{Instalación} * 8) + \text{Gravedad}$$

- El valor de prioridad es el primer valor en un paquete y ocurre entre paréntesis angulares (<>).

Syslog

- La sección **HEADER (Encabezado)** de mensajes contiene las marcas de tiempo en formato **MMM DD HH:MM:SS** .
- Si la marca de hora está precedida por los símbolos de punto (.) o de asterisco(*), se indica que hay un problema con NTP.
- La sección **HEADER** incluye también el nombre del host o la dirección IP del dispositivo que origina el mensaje.
- La sección de **MSG** contiene el significado del mensaje de Syslog. Esto puede variar entre los fabricantes de dispositivos y puede personalizarse.
- Por lo tanto, esta parte del mensaje es la más significativa y útil para el analista de ciberseguridad.

Archivos de registro de un servidor

- Los registros del servidor son una fuente esencial de información para el monitoreo de la seguridad de la red.
- Los registros de servidores proxy de DNS son particularmente importantes, dado que documentan todas las consultas y respuestas de DNS que tienen lugar en la red.
- Hay dos archivos de registro importantes los archivos de registro de servidores web Apache y los archivos de registro de acceso de Microsoft Internet Information Server (IIS).

Registro de acceso de Apache

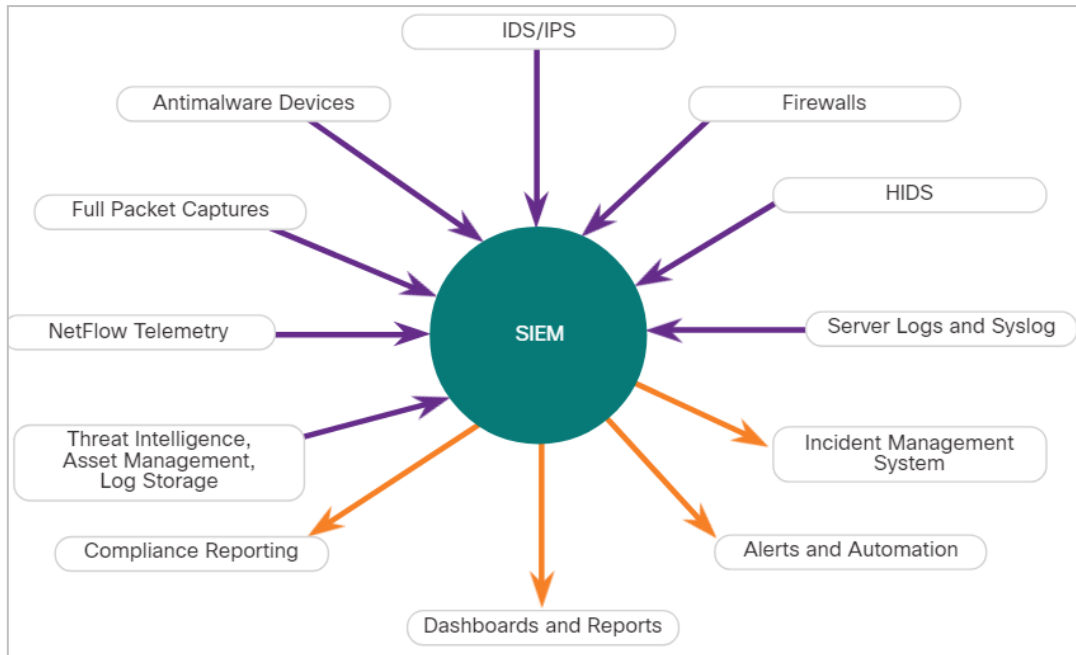
```
203.0.113.127 - dsmith [10/Oct/2016:10:26:57 - 0500] "GET /logo_sm.gif HTTP/1.0" 200 2254  
""http://www.example.com/links.html"" "Mozilla/5.0 (Windows NT 6.1; Win64; x64; rv:47.0) Gecko/20100101  
Firefox/47.0"
```

Registro de acceso de IIS

```
6/14/2016, 16:22:43, 203.0.113.24, -, W3SVC2, WEB3, 198.51.100.10, 80, GET, /home.htm, -, 200, 0, 15321,  
159, 15, HTTP/1.1, Mozilla/5.0 (compatible; MSIE 9.0; Windows Phone OS 7.5; Trident/5.0; IEMobile/9.0),  
-, http://www.example.com
```

SIEM y la recopilación de archivos de registro

La tecnología de administración de información y eventos de seguridad (SIEM) es utilizada en muchas organizaciones para proporcionar informes en tiempo real y análisis a largo plazo de eventos de seguridad, como se ve en la Figura.



Entradas y salidas SIEM

SIEM y la recopilación de registro

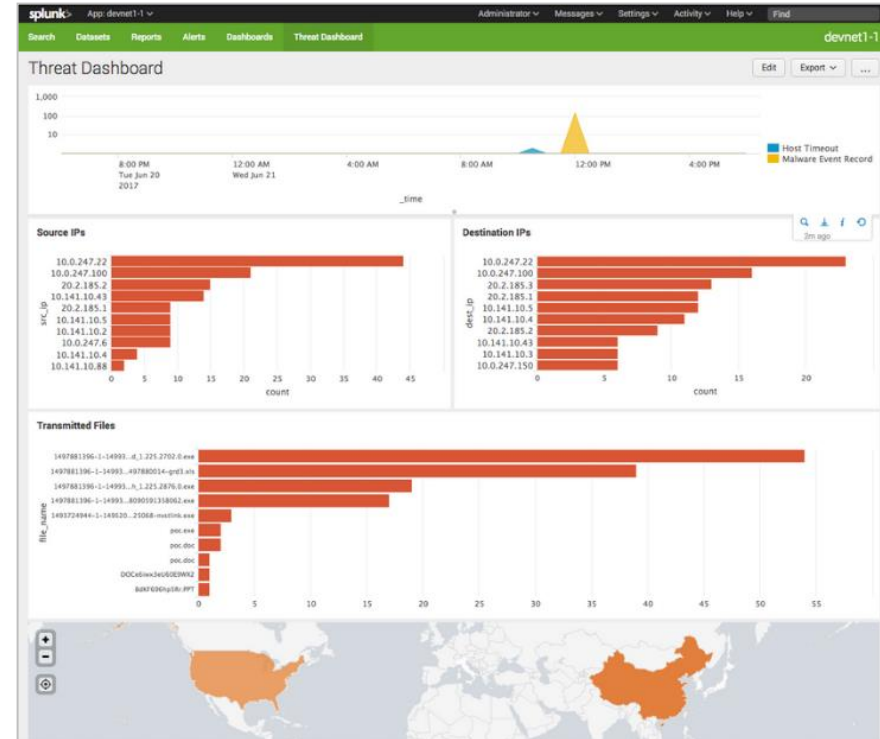
SIEM combina las funciones esenciales de las herramientas de administración de eventos de seguridad (SEM) y administración de información de seguridad (SIM) para brindar una perspectiva integral de las redes empresariales mediante las siguientes funciones:

- **Recopilación de registros** – Estos registros de eventos obtenidos de fuentes en toda la organización proporcionan importante información de informática forense y ayudan a abordar requisitos de los informes de cumplimiento.
- **Normalización** – Esta función integra mensajes de registro de diferentes sistemas en un modelo común de datos, lo que le permite a la organización conectar y analizar eventos relacionados, incluso si inicialmente se registraron en diferentes formatos de origen.
- **Correlación** – Esta función vincula registros y eventos de sistemas o aplicaciones separados, lo que acelera la detección de las amenazas de seguridad y la capacidad de reacción ante ellas.
- **Agregación** – Esta función reduce el volumen de datos de eventos mediante la consolidación de registros de eventos duplicados.
- **Generación de informes** – Esta función presenta los datos del evento correlacionado y unificados en el monitoreo en tiempo real y en resúmenes a largo plazo, incluidos tableros gráficos interactivos.
- **Cumplimiento** – Esta función permite generar informes para satisfacer los requerimientos de diferentes reglas de cumplimiento.

SIEM y la recopilación de registro

- Una SIEM muy conocida es Splunk, diseñada por un Cisco partner.
- La figura muestra un panel de amenazas Splunk. Splunk es ampliamente usado en SOC.
- Debido a la falta de profesionales de ciberseguridad para monitorear y analizar el gran volumen de datos de seguridad, es importante que las herramientas de varios proveedores se puedan integrar en una sola plataforma.
- Las plataformas de seguridad integradas van más allá de SIEM y SOAR para unificar múltiples tecnologías de seguridad en un equipo unificado.

Panel de amenazas Splunk



25.3 Registros de red

Tcpdump

- La herramienta de línea de comando tcpdump es un analizador de paquetes muy popular.
- Puede mostrar capturas de paquetes en tiempo real o escribir capturas de paquetes en un archivo.
- Captura datos detallados sobre los protocolos y el contenido de los paquetes.
- Wireshark es una GUI diseñada sobre la base de la funcionalidad tcpdump.
- La estructura de las capturas de tcpdump varía según el protocolo capturado y los campos solicitados.



Un dominio de difusión amplio

NetFlow

- NetFlow es un protocolo desarrollado por Cisco como herramienta para la solución de problemas de red y la auditoría con base en la red.
- NetFlow proporciona un importante conjunto de servicios para aplicaciones IP, en el que se incluye auditoría de tráfico de red, facturación de redes con base en el uso, planificación de la red, seguridad, funcionalidades de monitoreo de denegación de servicio y monitoreo de la red.
- También brinda información sobre usuarios de redes, aplicaciones, tiempos máximos de uso y routing de tráfico.
- Registra información sobre el flujo de paquetes, incluidos los metadatos. Cisco desarrollo NetFlow y luego permitió que se utilizara como base para un estándar de IETF llamado IPFIX.
- La información de NetFlow puede ser visualizada con herramientas como nfdump.
- nfdump proporciona una utilidad de línea de comando para visualizar datos de NetFlow desde el daemon de captura o recopilador de nfcapd.

Registros de redes

NetFlow

Panel de datos de sesión de FlowViewer NetFlow

- Existen herramientas que agregan funcionalidad de GUI a la visualización de flujos.
- La Figura muestra una pantalla de la herramienta de código abierto FlowViewer.



NetFlow

- Un flujo de IP está basado en un conjunto de 5 a 7 atributos de paquetes IP que fluye en una sola dirección. Un flujo se compone de todos los paquetes transmitidos hasta que finaliza la conversación de TCP.
- Los atributos de paquete IP utilizados por NetFlow son la dirección de origen IP, la dirección de destino IP, el puerto de origen, el puerto de destino, el tipo de protocolo de capa 3, la clase de servicio, el enrutador o la interfaz del conmutador.
- La metodología de tomar las huellas digitales de un flujo o determinar si es escalable, se debe a que se condensa una gran cantidad de información de la red en una base de datos de información de NetFlow denominada caché de NetFlow.
- Todos los registros de flujo de NetFlow contendrán los cinco primeros elementos de la lista de arriba y las marcas de tiempo de inicio y final del flujo.
- La información adicional que puede aparecer es muy variable y se puede configurar en el dispositivo exportador NetFlow Exporter.
- Los exportadores son dispositivos que se pueden configurar para crear registros de flujo y transmitirlos para su almacenamiento en un dispositivo recopilador de NetFlow.

NetFlow

- Un ejemplo de un registro de flujo básico de NetFlow en dos presentaciones diferentes, es mostrado en la figura.

```

Date      flow start      Duration  Proto Src IP Addr:Port  Dst IP Addr:Port  Flags Tos Packets Bytes
Flows2017-08-30 00:09:12.596  00.010    TCP   10.1.1.2:80        -> 13.1.1.2:8974    .AP.SF  0    62
3512      1

```

```

Traffic Contribution: 8% (3/37)Flow information:IPV4 SOURCE ADDRESS:10.1.1.2IPV4 DESTINATION
ADDRESS:13.1.1.2INTERFACE INPUT:Se0/0/1TRNS SOURCE PORT:8974TRNS DESTINATION PORT:80IP TOS:0x00IP
PROTOCOL:6FLOW SAMPLER ID:0FLOW DIRECTION:Inputipv4 source mask:/0ipv4 destination mask:/8counter
bytes:205ipv4 next hop address:13.1.1.2tcp flags:0x1binterface output:Fa0/0counter packets:5timestamp
first:00:09:12.596timestamp last:00:09:12.606ip source as:0ip destination as:0

```

- Hay disponible una gran cantidad de atributos para un flujo. El registro IANA de entidades IPFIX enumera varios cientos, y los primeros 128 son los más comunes.
- NetFlow es una herramienta útil en el análisis de incidentes de seguridad de red. Puede ser utilizada para crear una línea de tiempo de los ataques, comprender el comportamiento de un host individual, o rastrear el movimiento de un atacante o un ataque de host a host dentro de una red.

Visibilidad y control de aplicaciones

- El sistema Cisco Application Visibility and Control (AVC) combina varias tecnologías para reconocer, analizar y controlar más de 1000 aplicaciones.
- Estas incluyen voz y vídeo, correo electrónico, uso compartido de archivos, juegos, Peer-to-Peer (P2P) y aplicaciones con base en la nube.
- AVC utiliza el reconocimiento de aplicaciones basadas en la red (NBAR2) de última generación de Cisco para detectar y clasificar las aplicaciones en uso en la red.
- El motor de aplicación reconocimiento NBAR2 admite más de 1000 aplicaciones de red.
- La identificación de aplicaciones de red por puerto no permite ver en detalle el comportamiento de los usuarios.
- La visibilidad de la aplicación mediante la identificación de firmas de las aplicaciones permite identificar qué hacen los usuarios, ya sea participar de una teleconferencia o descargar películas en sus teléfonos.

Visibilidad y control de aplicaciones



Reconocimiento de aplicaciones

Identificar aplicaciones mediante el uso de datos L3 al L7

Más de 1000 aplicaciones

- Servicios en la nube
- Cisco Webex
- YouTube
- Skype
- P2P

NBAR2




Recopilación de métricas

Recolectar métricas para exportar a la herramienta de gestión

- Uso de ancho de banda
- Tiempo de respuesta
- Latencia
- Pérdida de paquetes
- Fluctuación de fase
- P2P

Netflow9 Flexible Netflow
IPFIX



Management and
Reporting Tools

Administración y elaboración de informes

Abastecer la red, recopilar datos e informar sobre el rendimiento de las aplicaciones

- Generación de informes
- Administración de políticas

Cisco Prime otro software de terceros



High: VoIP
Medium: Browsing
Low: Streaming
Blocked: P2P

Control

Control del uso de aplicaciones para maximizar el rendimiento de la red

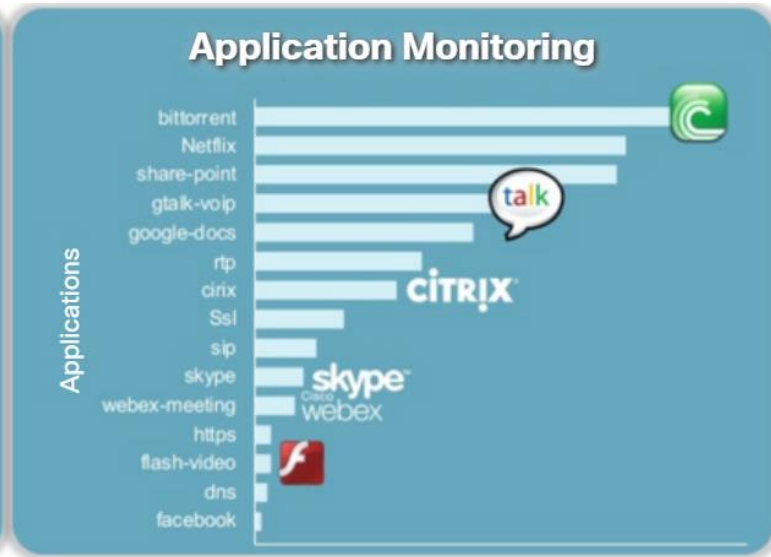
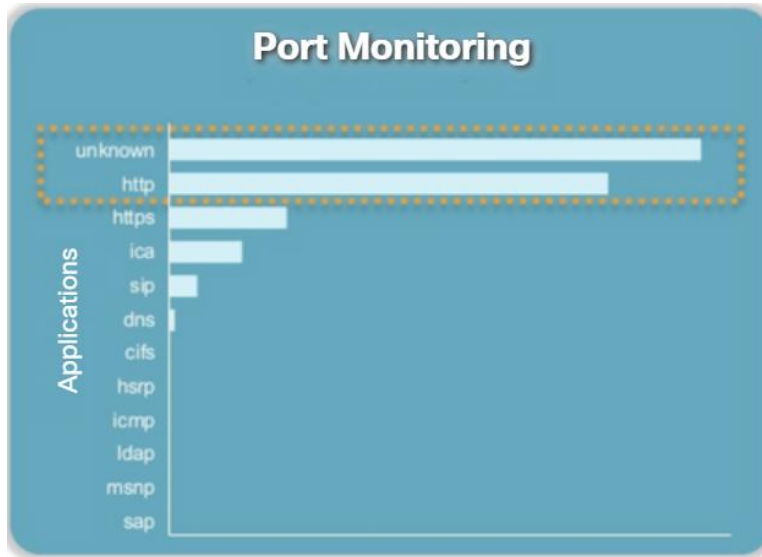
- Priorización de las aplicaciones
- Refuerzo del ancho de banda de aplicación

QoS

Visibilidad y control de aplicaciones

Supervisión de puertos frente a supervisión de aplicaciones

Un sistema de administración y generación de informes, analiza y presenta los datos de análisis de las aplicaciones en informes de tipo tablero para que los use el personal de monitoreo de la red. También es posible controlar el uso de aplicaciones mediante la clasificación y las políticas de calidad de servicio con base en la información de AVC.

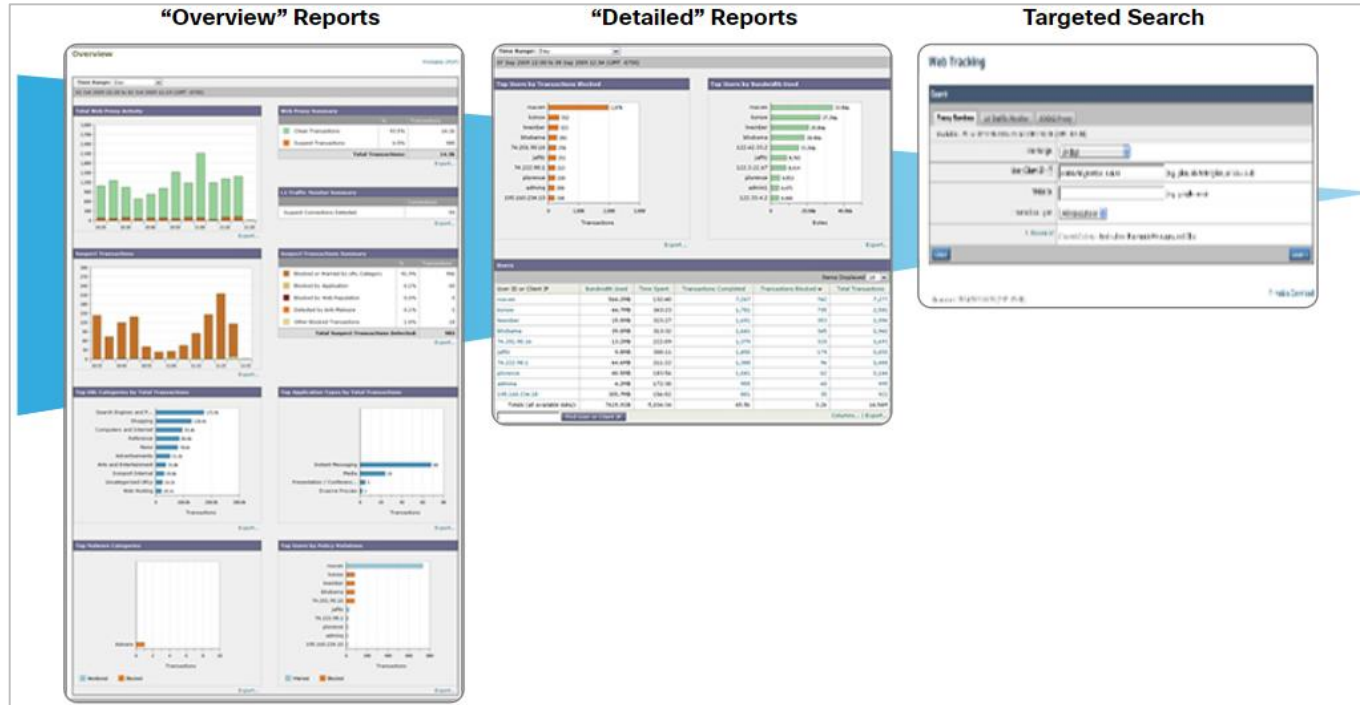


Archivos de registro de filtros de contenido

- Los dispositivos que proporcionan filtrado de contenido, como Cisco Email Security Appliance (ESA) y Cisco Web Security Appliance (WSA), ofrecen una amplia gama de funcionalidades para el monitoreo de la seguridad.
- La ESA tiene más de treinta registros que pueden usarse para monitorear la mayoría de los aspectos de entrega de correo electrónico, funcionamiento del sistema, antivirus, operaciones antispam y decisiones de lista negra y lista blanca.
- La mayoría de los registros se almacena en archivos de texto y puede recogerse en servidores syslog o puede enviarse a servidores FTP o SCP.
- Las alertas respecto al funcionamiento del dispositivo en sí mismo y de sus subsistemas pueden monitorearse mediante el envío de correo electrónico a los administradores que son responsables del monitoreo y el funcionamiento del dispositivo.
- Los dispositivos WSA ofrecen un funcionamiento detallado similar. WSA se desempeña con eficacia como un proxy web, lo que significa que registra toda la información de transacciones entrantes y salientes para el tráfico HTTP.
- El WSA puede configurarse en un formato de compatibilidad W3C para enviar los registros a un servidor de diversas maneras, entre ellas, syslog, FTP y SCP.

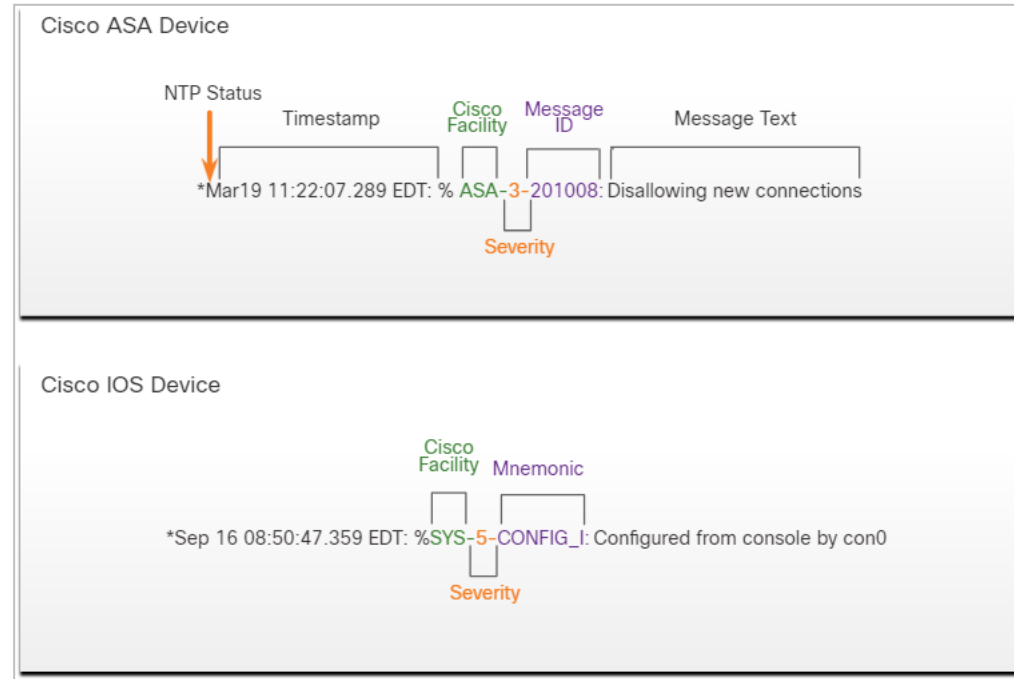
Registro de filtro de contenido

La figura muestra el panel "profundizado" de los dispositivos de filtrado de contenido pertenecientes a Cisco. Al hacer clic en los componentes de los informes de descripción general, se muestran detalles más relevantes. Las búsquedas de destino proporcionan la información centrada.



Generar archivos de registro desde dispositivos Cisco

- Los dispositivos de seguridad de Cisco se pueden configurar para que envíen eventos y alertas a las plataformas de administración de la seguridad utilizando SNMP o syslog.
- La figura muestra un mensaje de syslog generado por un dispositivo Cisco ASA y un mensaje de syslog generado por un dispositivo Cisco IOS.
- Hay dos significados utilizados para el termino instalación en los mensajes de Cisco syslog.
- El primero es el conjunto estándar de valores de componentes que establecieron los estándares de syslog.
- El otro valor de instalación lo asigna Cisco y tiene lugar en la parte de MSG del mensaje de syslog.



Archivos de registro del proxy

- Los servidores proxy, como los utilizados para las solicitudes web y de DNS, contienen registros valiosos que son una fuente principal de datos para el monitoreo de seguridad de la red.
- Los servidores proxy son dispositivos que actúan como intermediarios para los clientes de la red.
- El servidor proxy solicita los recursos y los devuelve al cliente generando registros de todas las solicitudes y respuestas.
- Luego, estos registros pueden analizarse para determinar qué hosts realizan las solicitudes y si los destinos son seguros o podrían ser maliciosos, y también para entender mejor qué tipos de recursos se descargan.
- Los proxies web proporcionan datos que ayudan a determinar si las respuestas de la web se generaron en respuesta a solicitudes legítimas o si se manipularon para parecer respuestas, pero en realidad son ataques.
- También es posible usar proxies web para inspeccionar el tráfico saliente como medio de prevención de pérdida de datos (DLP). La DLP implica analizar el tráfico saliente para detectar si los datos que están dejando la web contienen información confidencial o secreta.

Registros de proxy

Ejemplo de registro de proxy DNS

Un ejemplo de un registro de proxy web Squid en el formato nativo de Squid aparece debajo. Explicación del valor de cada campo que aparece en la siguiente tabla de registros de entradas.

```
1265939281.764      19478 172.16.167.228 TCP_MISS/200 864 GEThttp://www.example.com//images/home.png -  
NONE/- image/png
```

Valor del registro de proxy	Explicación
1265939281.764	Tiempo - en formato de marca de tiempo Unix Epoch en milisegundos
19478	Duración - El tiempo transcurrido entre la solicitud y respuesta de Squid
172.16.167.228	Dirección IP del cliente
TCP_MISS/200	Resultado - Código de resultado Squid y estado de codigo HTTP separados con una barra diagonal

Registros de proxy

Valor del registro de proxy	Explicación
864	Tamaño: los bytes de los datos entregados
GET	Solicitud- Solicitud HTTP realizada por el cliente
http://www.example.com//images/home.png	URI/URL - Dirección del recurso solicitado
-	Identificación del cliente - Valor RFC 1413 para el cliente que realizó la solicitud. No se utiliza de forma predeterminada.
NONE/-	Código de emparejamiento/Host Par - Servidor de caché de vecino consultado
image/png	Tipo - Tipo de contenido MIME proveniente del valor Content-Type en el encabezado de la respuesta HTTP

Nota: Los proxies web abiertos, que son proxies que están disponibles para cualquier usuario de internet, se pueden utilizar para ocultar direcciones IP de agentes de amenaza. Las direcciones de proxy abierto pueden formar parte de las listas negras del tráfico de Internet.

Registros de proxy

Cisco Umbrella

- Cisco Umbrella, antes OpenDNS, ofrece un servicio de DNS en el host que extiende la capacidad de DNS para incluir mejoras en la seguridad.
- En lugar de que haya organizaciones que almacenen y mantengan listas negras, protección contra phishing y otras herramientas de seguridad relacionadas con el DNS, ofrece estas protecciones en su propio servicio de DNS.
- Cisco Umbrella aplica muchos más recursos de administración DNS que la mayoría de las organizaciones puede ofrecer. Cisco Umbrella funciona en parte como un súper proxy de DNS.
- El suite de productos de seguridad de Cisco Umbrella aplica inteligencia de amenazas a tiempo real para administrar el acceso a DNS y la seguridad de los registros de DNS
- Los registros de acceso DNS están disponibles en Cisco Umbrella para las empresas suscritas.
- A continuación aparece un ejemplo de un registro de proxy DNS.

```
"2015-01-16 17:48:41","ActiveDirectoryUserName",  
"ActiveDirectoryUserName,ADSite,Network",  
"10.10.1.100","24.123.132.133","Allowed","1 (A)",  
"NOERROR","domain-visited.com.",  
"Chat,Photo Sharing,Social Networking,Allow List"
```

Registros de redes

Registros de proxy

La tabla explica el significado de los campos en la entrada de registro:

Prot.	Ejemplo	Explicación
Marca de hora	2015-01-16 17:48:41	Esto es cuando esta solicitud se realizó en UTC. Esto es diferente al panel de control Umbrella, que convierte la hora a la zona horaria especificada.
Policy Identity	ActiveDirectoryUserName	La primera identidad que coincide con la solicitud.
Identidades	ActiveDirectoryUserName, AdSite, Red	Todas las identidades asociadas con esta solicitud.
Dirección IP interna	10.10.1.100	La dirección IP interna que realizó la solicitud.
Dirección IP externa	24.123.132.133	La dirección IP externa que realizó la solicitud.
Acción	Permitido	Si la solicitud estaba permitida o bloqueada.
Tipo de consulta	1 A)	El tipo de solicitud DNS que se realizó.
ResponseCode	NOERROR	El código de devolución DNS para esta solicitud.
Dominio	domain-visited.com.	Este es el dominio que se solicitó.
Categorías	Chat, Compartir fotos, Redes sociales	Las categorías de seguridad o contenido que coincide con el destino.

Firewalls de próxima generación

- Los dispositivos de Firewall Next-Generation o NextGen extienden la seguridad en la red más allá de las direcciones IP y los números de puerto de capa 4 hasta la capa de aplicación y más allá.
- Los Firewall NextGen son dispositivos avanzados que proporcionan mucha más funcionalidad que las generaciones anteriores de dispositivos de seguridad de red.
- Una funcionalidad son los tableros de informes con funciones interactivas que permiten obtener informes rápidos con un solo clic sobre información muy específica sin la necesidad de SIEM u otros correlacionadores de eventos.
- La línea de dispositivos FireWall NextGen de Cisco (NGFW) utiliza servicios FirePower para consolidar múltiples capas de seguridad en una sola plataforma. Esto ayuda a contener los costos y simplificar la administración.
- Los servicios FirePower incluyen visibilidad y control de las aplicaciones, FirePower NextGen IPS (NGIPS), filtrado de URL por categorías y reputación, y protección avanzada contra malware (AMP).
- Los dispositivos FirePower permiten el monitoreo de seguridad de la red con una GUI habilitada para la web y denominada Visor de eventos.

Next-Generation FireWalls

Los eventos NGFW comunes incluyen:

- **Evento de conexión:** Los registros de conexión contienen datos sobre las sesiones que NIGPS detecta directamente. Los eventos de conexión incluyen propiedades de conexión básica, como marcas de tiempo, IP de origen y destino, y metadatos sobre por qué la conexión se registró, por ejemplo, qué regla de control de acceso registró el evento.
- **Evento de intrusión:** El sistema examina los paquetes que atraviesan la red en busca de actividades maliciosas que podrían afectar la disponibilidad, integridad y confidencialidad de un host y sus datos. Cuando el sistema identifica una posible intrusión, genera un evento de intrusión, que es un registro de la fecha, la hora, el tipo de ataque y la información contextual sobre el origen del ataque y su destino.
- **Host o evento de terminal:** cuando un host aparece en la red, el sistema puede detectarlo y registrar detalles del hardware del dispositivo, las direcciones IP y la última presencia conocida en la red.

Next-Generation FireWalls

- **Eventos de descubrimiento de red:**

Estos representan cambios que se hayan detectado en la red monitoreada. Estos cambios se registran en respuesta a las políticas de descubrimiento de la red que especifican los tipos de datos que se recopilarán, los segmentos de la red que se monitorearán y las interfaces de hardware del dispositivo que deben utilizarse para la recopilación de eventos.

- **Evento de NetFlow:** La detección de la red puede utilizar una serie de mecanismos; uno de ellos es utilizar registros de flujo de NetFlow exportados para generar eventos nuevos para hosts y servidores.

Servicios prestados por NGFW



Packet Tracer: Explorar una implementación de NetFlow

En esta actividad de Packet Tracer, hará lo siguiente:

- Explore una implementación de NetFlow.

Packet Tracer: Generar archivos de registro desde varias fuentes

En esta actividad de Packet Tracer, hará lo siguiente:

- Utilice Packet Tracer para comparar datos de red generados por múltiples fuentes incluyendo syslog, AAA y NetFlow.

25.4 Resumen: Datos de seguridad de la red

¿Qué aprendí en este módulo?

- Los datos de alertas son mensajes generados por sistemas de prevención de intrusiones (IPS) o sistemas de detección de intrusiones (IDS) para responder al tráfico que viola una regla o coincide con la firma de un ataque conocido.
- Snort genera las alertas y es posible leerlas y buscarlas con aplicaciones como Sguil, Squert y Kibana que forman parte del conjunto Security Onion de herramientas de NSM.
- Los datos de la sesión incluyen información de identificación, como las cinco tuplas de direcciones IP de origen y destino, los números de puerto de origen y de destino, y el código IP del protocolo en uso.
- Los datos sobre la sesión suelen incluir un identificador de la sesión, la cantidad de datos transferidos por el origen y el destino, e información relativa a la duración de la sesión.
- La captura completa de paquetes contiene todo el material de las conversaciones, como los mensajes de texto o correo electrónico, el HTML de las páginas web y los archivos que ingresan o salen de la red.
- Los datos estadísticos son creados a través del análisis de varias formas de datos de red

¿Qué aprendí en este módulo?

- El sistema de detección de intrusiones basado en hosts (Host-based Intrusion detection system, HIDS), se ejecuta en hosts individuales.
- Syslog incluye especificaciones para formatos de mensajes, una estructura de aplicación de cliente y servidor, y un protocolo de red.
- Los registros del servidor son una fuente esencial de información para el monitoreo de la seguridad de la red.
- El servidor proxy DNS registra todas las consultas y respuestas de DNS que ocurren dentro de la red.
- Los registros del proxy de DNS son útiles para la identificación de hosts que podrían haber visitado sitios web peligrosos y para la identificación de ex-filtración de datos de DNS y conexiones a servidores de comando y control de malware.
- SIEM combina las funciones esenciales de las herramientas de administración de eventos de seguridad (SEM) y administración de información de seguridad (SIM) para brindar una perspectiva comprensible de las redes empresariales usando recolectores de registros, normalización, correlación, agregación, reporte y conformidad

¿Qué aprendí en este módulo?

- La herramienta de línea de comando tcpdump es un analizador de paquetes muy popular. Puede mostrar capturas de paquetes en tiempo real o escribir capturas de paquetes en un archivo.
- NetFlow brinda información valiosa acerca de los usuarios y las aplicaciones de la red, horarios pico de uso y routing de tráfico.
- Cisco Application Visibility and Control utiliza Cisco de próxima generación de reconocimiento de aplicaciones basadas en red versión 2 (NBAR2), también conocido como NBAR de próxima generación.
- Los dispositivos como Cisco Email Security Appliance (ESA) y Cisco Web Security Appliance (WSA), ofrecen una amplia gama de funcionalidades para el monitoreo de la seguridad utilizando filtro de contenido.
- Los servidores proxy son dispositivos que actúan como intermediarios para los clientes de la red.
- Los dispositivos de Firewall NextGen extienden la seguridad en la red más allá de las direcciones IP y los números de puerto de capa 4 hasta la capa de aplicación y más allá.

